GOOGLE CLOUD ZERO-TRUST AI SECURITY & ISO/IEC 42001 AIMS GOVERNANCE PLATFORM

Assurance, Governance & Continuous AI Auditing

End-to-end platform to assess, audit, and harden Enterprise Artificial Intelligence Architectures (GenAI, LLMs, Autonomous Agents, MCP & RAG) under global standards **OWASP AI-SVS v1.0 (Level L2/L3)** and **ISO/IEC 42001:2023**.

OWASP AI-SVS V1.0 (12 CHAPTERS) ISO/IEC 42001:2023 AIMS MODEL GARDEN & MODEL ARMOR (PHASE 3) VERTEX AI GEMINI 3.8 FLASH (KEYLESS ADC)

VERTEX EVALUATION AUTOSXS (PHASE 4) MODEL MONITORING & SCC AI (PHASE 5)

THE PROBLEM TO SOLVE

The Critical Security Blindspot in Enterprise GenAI Adoption

Enterprises are shipping generative AI models, agentic workflows, MCP tools, and RAG pipelines without architectural verification or ISO 42001 governance.

⚠ Ungoverned AI Access & Breaches

Per **IBM Cost of a Data Breach 2025**, **13% of organizations** reported breaches of AI models or applications, and **97% of those** lacked proper AI access controls or formal impact assessments (`ISO 42001 A.5.1`).

⚠ Multi-Turn & Agentic Attack Surface

RAG pipelines, MCP servers, and autonomous agents introduce critical vectors: **Multi-Turn Crescendo Prompt Injection** (`C02.10`), **Normative/Vector Poisoning** (`C01.4`), and SSRF/IMDS exfiltration (`C04.3`).

⚠ CISO vs Data Science Silo

Security teams lack tools to audit agent graphs, MCP manifests (`C10.1`), and pre-retrieval vector ACLs (`C08.1`); AI developers lack automated mappings to formal compliance clauses.

Lack of Operationalized Governance (ISO/IEC 42001)

Organizations struggle to operationalize **ISO/IEC 42001:2023** requirements—such as Corporate AI Policies (`A.2.1`), Confidential Whistleblowing (`A.3.3`), AI Asset Inventories (`A.4.1`), and Human Verdict Appeals (`A.5.2`)—into software engineering workflows.

Proliferation of "Shadow AI" & Denial of Wallet

Unregulated external API calls, timing-vulnerable token checks (`C05.3`), over-privileged service accounts (`C05.2`), missing Anti-DoW token budgets (`C11.1`), and exposed logit probabilities (`C11.4`).

Source: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

IMPACT OF INACTION

The Real Cost of Neglecting Proactive AI Assurance

Operating unverified AI systems exposes organizations to severe financial, regulatory, and operational liabilities.

€35M
or 7% of global annual turnover in statutory **EU AI Act Art. 99** penalties

97%
of breached AI apps lacked proper AI access controls (**IBM 2025**; 13% reported AI breaches)

10 / 10
Automated **OWASP LLM Top-10** risk checks enforced per audit

148
Built-in controls (AISVS 56, ISO 42001 54, EU AI Act 10, LFPDPPP 14, LFPC 14)

Exfiltration of Secrets, IMDS & PII

Multi-turn crescendo jailbreaks and SSRF payloads engineered to extract cloud metadata (`169.254.169.254`), API keys, or cross-tenant records when pre-retrieval ACLs (`C08.1`) are absent.

Regulatory Injunctions & Non-Conformity

Failure to demonstrate ISO/IEC 42001 AIMS controls, GDPR/LFPDPPP ARCO cascading deletion, or LFPC Art. 56 cooling-off mechanisms triggers mandatory shutdowns and statutory fines.

Unappealable Algorithmic Harm

Hallucinated compliance verdicts or biased automated decisions without human-in-the-loop appeal channels (`ISO 42001 A.5.2`) or ethics whistleblowing (`A.3.3`) erode institutional trust.

OUR SOLUTION

AegisAI: Comprehensive & Automated AI Assurance

Transforming AI security and ISO 42001 governance auditing from weeks of manual review into deterministic, evidence-backed verification.

🛡 Shift-Left Multi-Standard Verification

AegisAI inspects architecture documents, PDFs, ZIP bundles, microservice specs, and live GCP telemetry against **OWASP AI-SVS v1.0** and **ISO/IEC 42001:2023** simultaneously.

- Deterministic Map-Reduce evaluation with strict chapter enum schemas (`buildBatchChaptersSchema`).
- Mandatory verbatim citation grounding (`textoEvidencia` & `fuenteEvidencia`).
- Pre-inference DLP masking, Google Cloud Model Armor & C02.10 multi-turn crescendo prompt injection blocking.

⚡ 100% Remediated Architecture & Full Cookbook

Beyond diagnostics, AegisAI synthesizes a complete **Drop-in Replacement Architecture Specification** (Section 3, including the 3-Phase GCP Protection Stack) plus a full, untruncated **Patch Cookbook** (Section 4).

- Renders all `1..N` non-passing controls without truncation, even on 35+ finding multi-standard audits.
- Sentence-boundary summary extraction and accurate syntax tags (`typescript` , `hcl` , `yaml` , `python` , `bash`).
- Executive PDF & Markdown exports ready for certification auditors and engineering teams.

1. Cryptographic Integrity (C01.4)

Normative snapshots verified at startup against a SHA-256 manifest + signed Model Garden / Registry provenance.

2. Keyless GCP Live Scanner (C05.2)

Read-only inspection of Vertex AI, Model Armor, AutoSxS, Model Monitoring, SCC AI, Cloud Run & IAM.

3. Continuous AIMS Telemetry (C08.4)

Real-time KPI tracking of citation grounding coverage, JSON schema fidelity, AutoSxS & control posture.

COMPLIANCE MATRIX

Multi-Standard Framework Support & ISO/IEC 42001 AIMS

Simultaneous evaluation across global technical security standards, management systems, and regional privacy statutes.

Standard / Framework	Technical & Governance Scope	Key Controls Verified & Enforced by AegisAI	Assurance Level
OWASP AI-SVS v1.0	AI Security Verification Standard (12 Chapters)	`C01.4` SHA-256 & Model Garden, `C02.10` Model Armor & Crescendo Guard, `C04.1` Read-Only Container, `C04.3` Cloud IAP & SSRF Block, `C05.2–C05.4` Constant-Time Auth & IAM, `C08.1/C08.4` RAG ACLs & AutoSxS, `C09.4` Sagas, `C10.1–C10.5` MCP Security, `C11.1/C11.4` Anti-DoW & Logprobs Off, `C12.2` SCC AI Alerts.	L1 / L2 / L3 READY
ISO/IEC 42001:2023	AI Management System (AIMS Clauses 4–10 & Annex A)	`Clause 4.1/4.2` Context & Stakeholders, `Clause 5/A.2.1/A.2.3` Corporate AI Policy, `A.6.1.2/A.7.3` Model Garden/Registry, `A.6.2.6` Model Armor & Model Monitoring, `Clause 9.1/A.6.2.4` Vertex Evaluation (AutoSxS), `A.6.2.8` SCC AI Protection.	CERTIFICATION READY
Mexican Regulatory (2026)	Consumer Protection (LFPC) & Personal Data (LFPDPPP)	Algorithmic transparency, deceptive commercial pattern prevention, Art. 56 5-day cooling-off retraction, ARCO cascading deletion, and DLP PII masking.	REGIONAL STATUTORY
BYOF Custom Framework	*Bring Your Own Framework* (Multi-Tenant)	Admin-authenticated ingestion (`C05.3`) with SHA-256 integrity checks (`C01.4`) and pre-retrieval tenant domain ACL filtering (`allowedDomains` , `C08.1`).	TENANT ISOLATED

Unified Cross-Framework Map-Reduce: Evaluates 103+ combined OWASP AI-SVS & ISO/IEC 42001 controls in parallel batches using constrained chapter ID enums so ISO Clauses 9/10 and Annex A.9/A.10 never collide with OWASP C09/C10.

SOFTWARE ARCHITECTURE

4-Layer Zero-Trust & Defense-in-Depth Architecture

Hardened serverless architecture deployed on Google Cloud Run behind Identity-Aware Proxy (IAP) with keyless Vertex AI ADC inference.

1. Perimeter & SPA

- **Cloud IAP** (`--no-allow-unauthenticated`)
- **React 19 + TS + Vite**
- Firebase Auth OAuth 2.0 domain allowlist (`google.com` , `altostrat.com`)
- Embedded ISO 42001 Policy, Appeal (`A.5.2`) & Whistleblowing (`A.3.3`) UI

2. Hardened API & Model Armor

- **Read-Only Container** (`chmod -R a-w /app` , `C04.1`)
- **Google Cloud Model Armor** inline prompt/response sanitizer
- Constant-time token check (`crypto.timingSafeEqual` , `C05.3`)
- DNS Rebinding Guard (`C10.5`) & MCP Signature Verifier (`C10.1`)
- Anti-DoW Quotas (`C11.1`)

3. Keyless Vertex AI & Multi-LLM

- **Vertex AI** (`gemini-3.8-flash`) via keyless IAM ADC (no Gemini API key needed)
- **Model Garden / Registry** signed provenance (`C01.4`)
- Multi-Provider Engine (Claude, OpenRouter, OpenAI, Local Proxy)
- Multi-Turn Crescendo Detector (`C02.10`) & Logprobs Off (`C11.4`)
- Outbound SSRF/IMDS Block (`C04.3`)

4. Data, AutoSxS & SCC AI

- **Cloud Firestore** (`aegis-ai-db`) via Admin SDK (308/308 tests)
- **Vertex Evaluation (AutoSxS)** & **Model Monitoring** (skew/drift)
- **Security Command Center (SCC) AI Protection** real-time SOC alerts
- SHA-256 Manifest (`C01.4`) & Compensating Sagas (`C09.4`)

Zero-Trust Isolation & SCC AI Protection Alerting (C12.2):

Runtime state writes exclusively to Firestore (`system_config/admin_settings`) and ephemeral `/tmp/aegis-runtime-cache` . Every security event (prompt injection escalation, SSRF block, token mismatch, DoW quota breach, saga rollback) emits a structured JSON alert to Google Cloud Logging and **Security Command Center (SCC) with AI Protection** for real-time SOC response.

GOOGLE CLOUD AI PROTECTION LIFECYCLE (ISO/IEC 42001)

5 Native Google Cloud Security & Governance Products Across Phases 3, 4 & 5

How AegisAI operationalizes ISO/IEC 42001:2023 and OWASP AI-SVS v1.0 across Development, Evaluation, and Controlled Production Deployment.

PHASE 3 • DEVELOPMENT & PROTECTIONS

Design, Supply Chain & Inline Guardrails

• **Visual & Evidence-Based Gap Map:** Maps current vs. desired state (`L1/L2/L3`) with verbatim citations.
• **Model Garden / Model Registry:** Reviewed library (Garden) & private library (Registry). Models are signed & verified by Google and partners—preventing untrusted internet models with backdoors (`ISO A.6.1.2 / A.7.3` , `C01.4`).
• **Model Armor:** Inline in front of LLMs. Sanitizes inputs & outputs in real time, blocks prompt injections & jailbreaks, and filters toxic content from user and model responses alike (`ISO A.6.2.6` , `C02.10`).

PHASE 4 • EVALUATION OF CONTROLS

Automated Review & ISO 42001 Audit Trail

• **Vertex Evaluation Service (AutoSxS):** Integrated Vertex AI evaluation framework using **AutoSxS**—which automatically categorizes and grades model responses like a teacher grading a student's homework.
• **Safety Metrics:** Evaluates hate speech, harassment, sexually explicit content, and dangerous content.
• **Cost-Effective Audit Trail:** Faster and more economical than manual review by human specialists, generating the audit trail required by `ISO/IEC 42001 Clause 9.1 & A.6.2.4` (`OWASP C08.4`).

PHASE 5 • CONTROLLED DEPLOYMENT

Drift Detection & Real-Time SOC Alerting

• **Vertex AI Model Monitoring:** Evaluates production performance by detecting **training-serving skew** (when live data differs from training data) and **drift** (when the world changes and the model becomes obsolete), alerting immediately if safety degrades (`ISO Clause 9.1 / A.6.2.6`).
• **Security Command Center (SCC) with AI Protection:** Threat & vulnerability detection integrated with Vertex AI. Prompt injection attempts surface as real-time security alerts so the SOC can respond in time (`ISO A.6.2.8 / C12.2`).

Live GCP Scanner & Remediated Blueprint Integration: AegisAI's Live GCP Scanner inspects all 5 services via ephemeral read-only OAuth tokens, and Section 3.4 of every generated Remediated Architecture Blueprint outputs drop-in Terraform/TypeScript enforcement recipes for all 3 phases.

OPERATIONAL EXECUTION

The Auditor's Workflow: From Ingestion to 100% Hardening

Six-stage deterministic assurance lifecycle with built-in human oversight and automated code remediation.

1. **Authenticated Ingestion & Model Armor Guardrails**
   Corporate user (verified via Cloud IAP + Firebase ID Token) uploads PDFs/ZIPs/specs; Model Armor, `inspectPromptAndTrackSession` (`C02.10`) and DLP masking sanitize input.

2. **SHA-256 Verified & Model Garden Provenance**
   Normative snapshots verified against `integrity-manifest.json` (`C01.4`), signed Model Garden/Registry check & custom frameworks filtered by `tenantDomain` (`C08.1`).

3. **Deterministic Vertex AI Map-Reduce & AutoSxS**
   `gemini-3.8-flash` (keyless ADC, `temperature: 0.0` , `responseLogprobs: false`) evaluates each batch with Vertex Evaluation Service (AutoSxS) audit trail.

4. **Visual Gap Map & Human Appeal (ISO A.5.2)**
   Interactive radar charts, evidence-based L1/L2/L3 gap map, and direct Verdict Appeal / Human Review workflow (`ai-appeals@aegisai.enterprise`).

5. **100% Remediated Architecture & Full Cookbook**
   Synthesizes Section 3 drop-in architecture (incl. 3-Phase GCP Protection Stack) + Section 4 Cookbook for all `1..N` findings with accurate syntax tags.

6. **Model Monitoring, SCC AI & Compensating Saga**
   Saved to Firestore with `ownerUid` attribution (`C05.4`), `runCompensatingSaga` rollback (`C09.4`), Model Monitoring skew/drift & SCC AI alerts.

ARCHITECTURE SPECS & DEVSECOPS VERIFICATION

Verified Security Benchmarks & Production Posture

Continuously validated through automated Firestore rules tests, OWASP AI-SVS verification harnesses, and Cloud Run preflight checks.

308/308
Cloud Firestore Security Rules unit tests passed (`projects:test`)

5 GCP AI
Native ISO 42001 Security Services across Phases 3, 4 & 5

0
Leaked secrets or broad IAM roles (`roles/viewer` pruned, `C05.2`)

97.8%
Self-Audit Score (100% ISO 42001 • 94.7% OWASP AI-SVS)

Hardened Cloud Run & 3-Phase GCP Protection

- **Immutable Container (C04.1):** Non-root `aegisuser` with `chmod -R a-w /app` .
- **Zero-Trust Perimeter (C04.3):** Cloud IAP + `--no-allow-unauthenticated` + VPC private egress + SSRF/IMDS blocker.
- **3-Phase GCP Stack:** Model Garden/Registry, Model Armor, Vertex Evaluation (AutoSxS), Model Monitoring & SCC AI Protection.
- **Anti-DoW FinOps Protection (C11.1):** Per-user sliding-window rate limits, concurrency caps, and 24h token budgets.

Keyless Vertex AI ADC, Multi-Provider & AIMS

- **Keyless Vertex AI (Default):** Connected to `gemini-3.8-flash` via IAM ADC without requiring a Gemini API key.
- **Multi-Provider Engine:** Supports Anthropic Claude, OpenRouter, OpenAI Direct & Local/Corporate Proxy.
- **SCC AI & Cloud Logging (C12.2):** Real-time alerts (`aegis-security-alerting-c12-2`) for SOC response.
- **Bilingual Documentation Suite:** 8 English & 9 Spanish Manuals + 3 Executive/FinOps/Master Decks.

END-TO-END REMEDIATION TRACEABILITY

OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Controls Enforced

Comprehensive architectural and governance controls implemented across code, container, cloud perimeter, and AIMS policies.

OWASP AI-SVS v1.0 Technical Controls (17 Hardened Domains)

- **C01.4 & C13.1 Supply Chain:** `verifyNormativeSnapshotsIntegrity()` SHA-256 manifest + signed Model Garden / Registry provenance.
- **C02.10 & C07.1 Prompt/Output Guard:** Google Cloud Model Armor inline sanitization + `inspectPromptAndTrackSession()` multi-turn blocker (HTTP 422).
- **C04.1 & C04.3 Infrastructure:** Read-only `/app` (`chmod -R a-w`), Cloud IAP, VPC egress & `validateOutboundEndpoint()` SSRF/IMDS block.
- **C05.2, C05.3 & C05.4 Auth/IAM:** Pruned `roles/viewer` on `aegis-runner-sa` , `crypto.timingSafeEqual` , Firebase ID token verification & Firestore `ownerUid` ACLs.
- **C08.1 & C08.4 RAG & Evaluation:** Tenant domain ACL pre-filtering, Vertex Evaluation Service (AutoSxS) & Model Monitoring skew/drift.
- **C09.4 & C10.1–C10.5 Agents/MCP:** `runCompensatingSaga()` rollback, MCP Ed25519/HMAC manifest verification, OAuth 2.1 PKCE & `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` & SCC AI Protection real-time SOC alerts.

ISO/IEC 42001:2023 AIMS Governance Controls (18 Clauses & Annex A)

- **Clause 4.1 & 4.2 Context & Stakeholders:** Formal internal/external issue matrix, societal role as AI assurance provider & stakeholder mapping.
- **Clause 5.1, 5.2, A.2.1 & A.2.3 Leadership & AI Policy:** Executive-approved Corporate AI Policy with annual revision cycle.
- **Clause 7.2, 7.3 & A.3.3 Competency & Whistleblowing:** Mandatory role training & confidential ethics reporting (`ai-ethics-whistleblower@aegisai.enterprise`).
- **A.4.1, A.6.1.2 & A.7.3 AI Asset & Model Supply Chain:** Cataloged models verified via Vertex AI Model Garden & private Model Registry.
- **A.5.1–A.5.3 & A.6.2.6 Impact, Appeals & Runtime Safety:** Formal AIIA methodology, human appeal channel, Model Armor & Vertex AI Model Monitoring.
- **Clause 9.1–9.3, A.6.2.4 & A.6.2.8 Assurance & SOC:** Vertex Evaluation (AutoSxS) audit trail, semi-annual internal audits & SCC AI Protection alerts.

EVOLUTION & ROADMAP

Next Horizons in AegisAI Platform Engineering

Our forward-looking roadmap to advance autonomous enterprise AI assurance and regulatory automation.

Q4 2026 • NEAR TERM

Native CI/CD Shift-Left Gates

Official **GitHub Actions** and **GitLab CI Runners** to automatically block pull requests introducing prompt injection vulnerabilities, unsigned MCP manifests, or unencrypted vector storage before merging.

Q1 2027 • MEDIUM TERM

Multi-Agent Graph Auditing

Specialized auditing module for complex autonomous agent workflows (LangGraph, CrewAI, AutoGen): tool authorization boundary checks, compensating saga verification, and inter-agent memory sandboxing.

Q2 2027 • LONG TERM

Autonomous IaC Remediation

One-click automated synthesis of **Terraform Modules** and **Helm Charts** that directly apply Cloud IAP, VPC Service Controls, and Model Armor remediation recipes to cloud clusters.

🎯 Conclusion: Security & Governance that Accelerate Innovation

AegisAI provides the **architectural certainty, cryptographic integrity, and 3-Phase ISO/IEC 42001 Google Cloud AI Protection Stack** needed for enterprises to deploy frontier AI systems on Google Cloud with complete confidence.

Contact: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI